Quarterly review

The review team

2026-11-05

How the twelve services held up this quarter, what was found, and what happens next.

This sample shows how a report design lays out a whole report: the title block, a cover page when the design draws one, the running header and the footer on every page, headings at three levels, lists, a table, a quote and code. The words are the same whichever design draws them, so two designs can be compared page by page.

Summary

- Twelve services were reviewed; nine passed without findings.
- Three had findings, one of them **high** severity, now fixed.
- Two findings are still open, and each has an owner and a date.
- No finding was exploited, and no customer data was exposed.

> A review says what was checked and what was found, and it says just as plainly what was not checked.

The quarter's work followed the plan agreed in July. Each service owner received the checklist two weeks before their slot, ran the automated checks themselves, and then sat with a reviewer for a working session of about two hours. The reviewer read the service's configuration, its deployment pipeline and the last three months of its access logs, and the owner explained anything that looked unusual. Every finding was written down during the session, agreed with the owner before the session ended, and entered in the tracker the same day.

The review covered the services that handle payments, routing, stock and identity. It did not cover the marketing site, the internal wiki or the two services that are being retired at the end of the year; those are listed under the scope section below with the reason each was left out.

Scope

The twelve services in scope were chosen because each of them either holds personal data, moves money, or can change what another service is allowed to do. For each one the review asked the same five questions:

1. Who can reach it, and from where?
2. What does it trust, and is that trust checked on every request?
3. What does it keep, for how long, and who can read it?
4. How is it deployed, and could a change reach production without review?
5. When it fails, does it fail closed, and does anyone notice?

The questions are deliberately plain. A service that answers all five clearly is usually a service whose owners understand it well, and the findings tend to be small. A service that struggles with one of them is where the review spends most of its time.

Left out of scope

Three services were left out. The marketing site serves only public pages and holds no data beyond its access logs, which are covered by the logging review in the spring. The internal wiki is moving to a hosted product in December, and reviewing the old installation now would be work thrown away. The legacy invoice exporter is switched off on the last day of November; its replacement, the billing gateway, is in scope and is reviewed below.

Findings

Five findings were raised across three services. The table lists each one with its severity, as the review scale defines it, and where it stands today.

Service	Finding	Severity	Status
billing-gateway	an expired certificate accepted on one internal call	high	fixed
route-planner	a debug endpoint reachable from the office network	medium	in progress
route-planner	access logs kept for two years, not ninety days	low	in progress
warehouse-sync	a shared service account used by two teams	low	accepted
warehouse-sync	no alert when the nightly sync fails	medium	fixed

The billing gateway

The billing gateway calls the ledger service over an internal connection. The client library it uses was configured to accept an expired certificate on that one call, a setting left over from a test environment two years ago. Nothing outside the company network could reach that connection, but a machine inside it could, in principle, have presented an old certificate and read invoice totals.

The fix was a one-line change to the client's configuration, deployed the same afternoon, and a test that fails the build if any client in the service is configured to accept an expired certificate again.

```
ssl_protocols TLSv1.2 TLSv1.3;
ssl_verify_client on;
```

The team also checked every other internal call the gateway makes. None of them had the same setting, and the new test now covers all of them.

The route planner

The route planner had a debug endpoint that answered on the office network. It returned the planner's current configuration, including the names of the depots and the time windows each one accepts. It did not return credentials, and it could not change anything, but it told anyone on the office network more than they needed to know. The endpoint is being removed from production builds; until the release that removes it ships, a rule at the load balancer refuses it.

The planner's access logs were also kept far longer than the policy allows. The logs themselves are harmless on their own, but together they show where every driver was at every hour for two years. The retention is being brought down to ninety days, and the older logs will be deleted once the finance team confirms it needs none of them for the audit.

The warehouse sync

The warehouse sync runs every night and copies stock levels from the warehouses into the ordering system. It failed silently twice in September, and the ordering system showed stale stock for a morning each time. An alert now fires when the sync has not finished by four in the morning, and it goes to the on-call engineer rather than to an inbox.

The sync also runs under a service account that the reporting team uses for its own nightly export. Splitting the account in two would mean changing a job the reporting team does not

own the code for, and the account can read stock levels and nothing else. The finding is accepted for now and will be looked at again when the reporting export is rewritten next year.

How the evidence was gathered

Every claim in this record rests on something a second person can check. For configuration, that is the file in the service's repository at the commit that was running on the day of the session. For access, it is the firewall rules and the identity provider's group memberships, exported on the same day. For behaviour, it is a test that anyone on the team can run again, or a log line with its time and the host that wrote it.

Where the review relied on what an owner said rather than on something written down, the finding says so. Two of this quarter's findings started that way: the owners of the warehouse sync told the reviewer that the nightly job had failed twice, and the alert was added before the logs that proved it had been found. Recording where each fact came from keeps the record honest when it is read again in a year, by people who were not in the room.

Nothing in this review was tested against production traffic. The checks ran against the staging copy of each service, which is built from the same configuration, and any difference between the two was itself treated as a finding.

What went well

Most of the services reviewed were in good shape, and some practices are worth spreading:

- The identity service rotates every one of its keys automatically, and its owners could show the last rotation of each key in the session.
- The ordering service refuses to start when a required setting is missing, instead of starting with a default that might be wrong.
- The payments team writes a short note in the tracker whenever it accepts a risk, with the date it will look again, and it keeps those dates.

> The best answer to "who can reach this?" was a diagram the owners drew from memory, and it matched the firewall rules exactly.

Several teams said the checklist was useful on its own, before the session. Two of them fixed things they found while filling it in, which is exactly what the checklist is for.

What we would change

The sessions ran long when the owner and the reviewer had not met before. Next quarter each reviewer will meet their service owners for fifteen minutes the week before, to agree what will be looked at and to collect anything the owners already know is wrong.

The tracker also grew a long tail of small notes that are not findings. Those will move to a separate list, so that the tracker holds only what someone has to act on.

Next steps

1. The routing team removes the debug endpoint in the November release.
2. The routing team brings log retention down to ninety days by 30 November.
3. The review team checks both fixes and updates this record.
4. The review team schedules next quarter's sessions by 15 December.

Each step has an owner and a date, and the review team will follow up on each one at the fortnightly check-in until it is closed.

Appendix: the review scale

A **high** finding could lead to data being read or changed by someone who should not have it, or money moving without approval, and it is fixed within a week. A **medium** finding makes such an event more likely or harder to notice, and it is fixed within a month. A **low** finding is a departure from policy with little direct risk, and it is fixed within a quarter or accepted with a date to look again. Every finding, whatever its severity, has a named owner from the day it is raised.